



Rapport d'Audit de Sécurité

OWASP Top 10 (2021) · OWASP WSTG v4.2

Application	ACRA — Augmented Cyber Risk Analysis
Version auditée	Next.js 14 · Prisma 5 · PostgreSQL 15
Date de l'audit	30 May 2026
Type d'audit	Revue de code statique + analyse architecturale
Périmètre	Code source applicatif (API routes, lib, composants UI)
Auditeur	Audit automatisé via analyse de code source
Classification	CONFIDENTIEL — Usage interne uniquement

50%

Score global OWASP
5/10 categories conformes ou corrigees
Audit base sur revue de code source statique

1. Synthèse exécutive

ACRA (Augmented Cyber Risk Analysis) est une application web Next.js 14 guidant les équipes dans la réalisation d'analyses de risques EBIOS RM. Cet audit couvre le code source applicatif contre les 10 catégories OWASP Top 10 (édition 2021) et 19 cas de test OWASP WSTG v4.2.

Catégorie	Nb items	Ratio
Conforme / Corrigé	5	5/10
Mitigé (résidu acceptable)	5	
Vulnérable (action requise)	0	

Points forts identifiés :

- Utilisation systématique de Prisma ORM — aucune injection SQL possible.
- Validation Zod sur tous les endpoints API — données malformées rejetées en entrée.
- Mots de passe hashés bcrypt cost=12 — résistant aux attaques offline.
- RBAC centralisé dans permissions.ts — contrôle d'accès homogène.
- En-têtes de sécurité HTTP configurés dans next.config.js (X-Frame-Options, CSP, HSTS prod).
- Cookies de session HttpOnly gérés par NextAuth — non accessibles en JavaScript.

Points d'amélioration prioritaires :

- Implémenter un logging structuré (Winston/Pino) avec audit trail des actions sensibles.
- Ajouter npm audit dans la pipeline CI/CD pour détecter les dépendances vulnérables.
- Considérer l'ajout d'une MFA (TOTP) pour les comptes ADMIN et RISK_MANAGER.
- Documenter la procédure de changement du NEXTAUTH_SECRET en production.
- Migrer le rate-limiter vers Redis si déploiement multi-instances.

2. Analyse OWASP Top 10 (2021)

Chaque catégorie a été évaluée par inspection statique du code source (API routes, middlewares, bibliothèques d'authentification, configuration). Les preuves citées font référence aux fichiers du dépôt.

A01:2021	Broken Access Control	✓ CORRIGÉ
Vérification	Inspection de toutes les routes API	
Preuves / Détail	Toutes les routes vérifient <code>getServerSession(). canViewAnalyse() / canEditAnalyse()</code> utilisés. IDOR corrige sur <code>/api/export/[id]</code> : remplace <code>findFirst({userId})</code> par <code>canViewAnalyse()</code> incluant les acces partages.	
A02:2021	Cryptographic Failures	✓ CONFORME
Vérification	Revue <code>auth.ts</code> , <code>register/route.ts</code> , <code>schema Prisma</code>	
Preuves / Détail	Mots de passe haches <code>bcrypt cost=12</code>. JWT NextAuth <code>NEXTAUTH_SECRET</code> requis. Champ <code>passwordHash</code> jamais expose dans les selects API. HSTS ajoute en production.	
A03:2021	Injection	✓ CONFORME
Vérification	Revue de toutes les requetes DB et inputs utilisateur	
Preuves / Détail	100% des requetes DB via Prisma ORM (requetes parametrees). Validation Zod sur tous les endpoints POST/PUT/PATCH. Aucun raw SQL dans le code applicatif (seulement migrations). CSV export: fonction <code>esc()</code> protege les guillemets.	
A04:2021	Insecure Design	■ MITIGÉ
Vérification	Test de scenarios de brute-force et abus	
Preuves / Détail	Rate limiting implemente dans <code>src/lib/rate-limit.ts</code> : - Login : 10 tentatives / 15 min / email (pas IP -> pas de faux positifs NAT) - Register : 5 inscriptions / heure / IP Limite inputs <code>ai-suggest</code> : contexte 500c, atelier 20c, question 300c. Limitation : <code>rate-limiter in-memory</code>, non partage si multi-instances.	
A05:2021	Security Misconfiguration	■ MITIGÉ
Vérification	Revue <code>next.config.js</code> , <code>.env.example</code> , headers HTTP	
Preuves / Détail	Headers : <code>X-Frame-Options DENY</code>, <code>X-Content-Type-Options</code>, <code>Referrer-Policy</code>, <code>Permissions-Policy</code>. CSP : <code>unsafe-eval</code> supprime (etait present). <code>unsafe-inline</code> conserve (requis Next.js). HSTS <code>max-age=31536000</code> ajoute en production uniquement. Point residuel : <code>.env.example</code> contient <code>NEXTAUTH_SECRET=changeme</code> -> documentation avertissement requis.	

A06:2021	Vulnerable and Outdated Components	■ MITIGÉ
Vérification	Verification package.json et CVE connus	
Preuves / Détail	Next.js 14, Prisma 5, bcryptjs, NextAuth 4 : versions recentes sans CVE critique connu au 05/2025. Recommandation : automatiser npm audit dans la CI/CD.	
A07:2021	Identification and Authentication Failures	■ MITIGÉ
Vérification	Revue auth.ts, flux de connexion, gestion sessions	
Preuves / Détail	bcrypt cost 12. JWT maxAge 30 jours (acceptable entreprise). Rate limiting sur login par email. Nouveau : changement de mot de passe avec verification ancien mot de passe. Point residuel : pas de MFA. Endpoint /api/auth/register ouvert (par conception, peut etre restreint).	
A08:2021	Software and Data Integrity Failures	✓ CONFORME
Vérification	Revue des deserializateurs et imports	
Preuves / Détail	Aucune deserialisation d'objets depuis des sources non fiables. JSON.parse utilise uniquement sur reponses API internes controlees. Zod valide la forme avant tout traitement.	
A09:2021	Security Logging and Monitoring Failures	■ MITIGÉ
Vérification	Revue des console.error et mecanismes de log	
Preuves / Détail	Logs actuels : console.error uniquement, pas de log structure. Pas d'audit trail des actions admin. Recommandation : integrer Winston/Pino avec niveaux, exporter vers SIEM. Logger connexions echouees, changements de role, suppressions d'analyses.	
A10:2021	Server-Side Request Forgery (SSRF)	✓ CONFORME
Vérification	Revue de tous les appels HTTP sortants	
Preuves / Détail	Un seul appel HTTP externe : /api/ai-suggest -> https://api.anthropic.com (URL fixe, non parametritable par l'utilisateur). Aucune fonctionnalite de proxy ou de fetch URL utilisateur.	

3. Analyse OWASP WSTG v4.2 (sélection)

Les cas de test WSTG ci-dessous ont été évalués par revue du code source, de la configuration Next.js et des bibliothèques utilisées.

ID	Test	Statut	Observation
WSTG-ATHN-01	Testing for Credentials Transported over an Encrypted Channel	■ MITIGÉ	CSP force HTTPS en prod. HSTS ajoute. En dev HTTP possible.
WSTG-ATHN-02	Testing for Default Credentials	✓ CONFORME	Aucun compte par défaut. Inscription obligatoire avec mot de passe.
WSTG-ATHN-03	Testing for Weak Lock Out Mechanism	■ MITIGÉ	Rate limiting par email (10/15min). Pas de verrouillage permanent de compte.
WSTG-ATHN-04	Testing for Bypassing Authentication Schema	✓ CONFORME	getSession() verifie systematiquement cote serveur. Middleware Next.js non utilise seul.
WSTG-ATHN-06	Testing for Browser Cache Weaknesses	✓ CONFORME	JWT stocke en cookie HttpOnly (NextAuth). Pas de credentials dans localStorage.
WSTG-ATHZ-01	Testing Directory Traversal / File Include	✓ CONFORME	Aucune lecture de fichier depuis param utilisateur. Export CSV genere en memoire.
WSTG-ATHZ-02	Testing for Bypassing Authorization Schema	✓ CONFORME	RBAC centralise dans permissions.ts. Verifie a chaque route. Tests de roles effectues.
WSTG-ATHZ-04	Testing for Insecure Direct Object Reference (IDOR)	✓ CORRIGÉ	Export: corrige de findFirst({userId}) vers canViewAnalyse(). Autres routes deja correctes.
WSTG-INPV-01	Testing for Reflected Cross Site Scripting	✓ CONFORME	React echappe automatiquement les valeurs JSX. Aucun dangerouslySetInnerHTML detecte.
WSTG-INPV-02	Testing for Stored Cross Site Scripting	✓ CONFORME	Donnees affichees via React (echappement automatique). CSP sans unsafe-eval.
WSTG-INPV-05	Testing for SQL Injection	✓ CONFORME	Prisma ORM exclusivement. Zod valide les types avant envoi. Aucune concatenation SQL.
WSTG-INPV-11	Testing for Code Injection	✓ CONFORME	Aucun eval(), new Function(), child_process depuis inputs utilisateur.
WSTG-SESS-01	Testing for Cookie Attributes	✓ CONFORME	Cookie de session NextAuth : HttpOnly, SameSite=Lax, Secure en production.
WSTG-SESS-02	Testing for Cookie Predictability	✓ CONFORME	JWT signe avec NEXTAUTH_SECRET aleatoire (openssl rand -base64 32 recommande).
WSTG-SESS-06	Testing for CSRF	✓ CONFORME	Toutes les mutations requierent une session JWT valide. NextAuth gere le CSRF token.
WSTG-CONF-07	Test HTTP Strict Transport Security	■ MITIGÉ	HSTS ajoute en production (NODE_ENV=production). Non actif en developpement.
WSTG-CONF-10	Test for Unnecessary HTTP Methods	✓ CONFORME	Seuls GET/POST/PUT/PATCH/DELETE sont implements. Next.js renvoie 405 sur methodes non definies.
WSTG-ERRH-01	Testing for Improper Error Handling	✓ CONFORME	Messages d'erreur generiques cote client. Details techniques dans console.error serveur seulement.

WSTG-CRYP-01	Testing for Weak Transport Layer Security	■ MITIGÉ	Depend de la configuration TLS du serveur/reverse proxy. HSTS configure. Recommande: TLS 1.2+ uniquement.
--------------	---	----------	---

4. Plan d'action recommandé

Priorité	Action	Référence	Effort
P1 - Urgent	Ajouter npm audit dans la CI/CD et bloquer les CVE critiques	A06:2021	Faible
P1 - Urgent	Documenter et enforcer le changement de NEXTAUTH_SECRET en production	A02:2021 / A05:2021	Faible
P2 - Important	Implémenter logging structuré (Winston) + audit trail admin/sécurité	A09:2021 / WSTG-ERRH-01	Moyen
P2 - Important	Migrer rate-limiter vers Redis si déploiement multi-instances	A04:2021 / A07:2021	Moyen
P3 - Souhaitable	Ajouter MFA (TOTP) pour comptes ADMIN et RISK_MANAGER	A07:2021	Élevé
P3 - Souhaitable	Renforcer TLS : TLS 1.2+ uniquement, cipher suites modernes (au niveau proxy)	WSTG-CRYP-01	Faible
P3 - Souhaitable	Refactorer CSP pour éliminer unsafe-inline (nonces Next.js 15)	A05:2021	Élevé

5. Méthodologie

Cet audit a été réalisé par **analyse statique du code source** (SAST). Il ne remplace pas un test d'intrusion dynamique (DAST/pentest). Les vérifications suivantes ont été effectuées :

- Inspection de toutes les routes API (src/app/api/**) : vérification des contrôles d'authentification, validation des inputs, gestion des erreurs.
- Revue de la bibliothèque d'authentification (src/lib/auth.ts) et des callbacks JWT.
- Analyse des schémas Zod sur chaque endpoint POST/PUT/PATCH.
- Vérification de l'absence de raw SQL (grep sur prisma.\$queryRaw, eval, dangerouslySetInnerHTML).
- Revue de next.config.js pour les en-têtes de sécurité HTTP.
- Inspection du .env.example pour les variables sensibles.
- Analyse des flux de contrôle d'accès (src/lib/permissions.ts) et de leur application.
- Vérification de la sanitisation du Content-Disposition dans l'export CSV.
- Test logique du rate-limiter : comportement NAT (rate limiting par email, pas IP sur login).

Rapport généré le 30/05/2026 — ACRA v1.0 — Classification : CONFIDENTIEL